

Industrial Security (Bachelor)

Exercise Sheet – Section 01 Introduction to Industrial Security

Goal of this sheet

These exercises ask you to *reason* about real plants, real incidents, and real trade-offs — not to recite definitions. Work through them in your tutorial group; most answers fit in 3–10 sentences or a short paragraph plus a small list.

Exercise 1.1 – Classify the System

For each of the following systems, decide whether it is primarily **IT**, **OT**, or **hybrid (IIoT)**. Justify your choice in 2–3 sentences, and name the criterion (real-time behaviour, coupling to a physical process, lifecycle, failure mode) that swung your decision.

1. A SQL database in the corporate datacentre holding 12 months of customer billing records.
2. A wind-turbine pitch controller that streams 50 Hz telemetry to an AWS MQTT broker.
3. An engineering workstation running TIA Portal, used twice a year to download new logic to a Siemens S7-1500.
4. A vibration sensor on a centrifugal pump that publishes to a corporate Kafka topic feeding a predictive-maintenance model.
5. A modern hospital infusion pump that adjusts dosing based on a barcode-driven medication record and a wireless drug library.

Exercise 1.2 – CIA Re-ordered, Concretely

The standard IT priority is $C \succ I \succ A$; in OT it is usually written $A \succ I \succ C$.

1. Give *one* concrete plant scenario where strict enforcement of **confidentiality** would directly harm **safety or availability**. Name the system, the control, and the failure mode.
2. Give *one* concrete OT scenario where confidentiality is nonetheless first-class (e.g. trade secret, formulation, dispatch curve).
3. In 4–5 lines, draft a policy sentence an asset owner could put in a plant security charter that makes the OT priority order explicit *and* non-trivial (i.e. not just “availability matters most”).

Exercise 1.3 – “Just Install Antivirus on the PLC”

A new IT auditor visits your brewery and writes the following finding: “*Critical PLCs on the bottling line have no endpoint protection. Install Microsoft Defender or equivalent on every PLC within 30 days.*” You are the OT security engineer who has to reply.

In 4–6 sentences, explain to the auditor why this finding is technically wrong *and* propose two compensating controls that achieve the underlying intent (catching malicious code on the bottling line). Be specific — name the type of device, the kind of control, and where in the network it sits.

Exercise 1.4 – Read an Advisory: AA22-103A

Open the joint CISA / NSA / FBI / DOE advisory **AA22-103A** (“APT Cyber Tools Targeting ICS/SCADA Devices”, 13 April 2022).

1. List the three ICS device families that the advisory names as targeted by the custom toolset.
2. Name the safety-system vendor and the family whose workstation is specifically called out (hint: a separate but companion vulnerability).
3. In two sentences, explain why this advisory was unusual at the time of publication (think about what was disclosed versus what is normally disclosed).

Exercise 1.5 – Brewery CISO: 30 Minutes In

You are the brand-new CISO at a mid-size German brewery (annual revenue $\approx$ €180 M). On day one, the plant manager tells you the SCADA HMI in the brewhouse has been “acting funny” for two days: occasional black screens, one spurious tank-level reading, and a CIP (clean-in-place) cycle that started on its own at 03:47 last night.

In 6–8 sentences:

1. State the first three concrete actions you take in the next 30 minutes, in order, and the reason for each.
2. Identify one action you would explicitly *not* take, and explain why doing it would make the situation worse.

Exercise 1.6 – Compensating Controls Under Constraint

A plant manager refuses to allow a firmware patch on a 2008-vintage Schneider Modicon Quantum PLC controlling a primary clarifier at a wastewater plant. Reasons given: (i) no maintenance window for the next 14 months, (ii) the vendor will not certify the patched firmware against the existing safety case, (iii) the plant is under a consent decree that penalises any unplanned downtime.

Write a one-paragraph proposal (6–8 sentences) of **three layered compensating controls** that reduce the risk of the unpatched CVE being exploited from the corporate network. For each control, name a concrete technology or product category (not a brand), where it sits in the Purdue model, and which threat actor tier it raises the bar against.

Exercise 1.7 – Compare Two Incidents

Pick **Maroochy Shire (2000)** and **Colonial Pipeline (2021)**.

In a short table or bullet list, compare them on five dimensions: *(a)* attacker profile and motive, *(b)* initial access vector, *(c)* where the harm landed (IT, OT, or the physical process), *(d)* whether the OT environment was directly attacked, and *(e)* the single most important defensive lesson the case carries for a present-day operator. Cite at least one primary source per incident (e.g. Queensland Parliament report, CISA advisory, US Senate hearing transcript).

Exercise 1.8 – Spot the Misconception

For each of the following statements, name the misconception, then refute it in 2–3 sentences with one concrete piece of evidence (incident, advisory, or technical fact). *Do not just say “this is wrong” — name what the speaker is missing.*

1. “Our plant is air-gapped, so we don’t need network monitoring.”
2. “We’ve never had an incident, so our controls are working.”
3. “We’re using Modbus over a private serial loop. Nobody knows that protocol.”
4. “We’re ISO 27001 certified. We’re secure.”

Exercise 1.9 – You Inherit an Undocumented Plant

You start as the OT security lead at a 30-year-old chemical plant. There is no asset inventory, no network diagram, no patch register, and the previous engineer left without a handover. The plant manager gives you exactly one hour with her on day one.

List the **first five questions** you will ask — in priority order — and for each one explain in one sentence why the answer changes what you do next. Aim for questions whose answer steers a major investment decision, not questions whose answer is a single number.

Exercise 1.10 – Cost Reasoning: NotPetya at Maersk

The June 2017 NotPetya outbreak cost A.P. Møller–Maersk a publicly disclosed US\$ 250–300 M (Q2 2017 interim report). The initial malicious payload was a backdoored update to M.E.Doc, a Ukrainian tax-accounting package used by one Maersk subsidiary.

1. In 3–4 sentences, explain how a single compromised tax-software update in Kyiv ended up shutting down container terminals in Rotterdam, Los Angeles, and Mumbai. Identify the two architectural properties that made the blast radius so large.
2. Estimate (with one sentence of reasoning) the ratio of *direct ransom cost* to *total disclosed loss* in this case, and contrast it with Colonial Pipeline 2021. What does that ratio tell a board about where to spend the next security euro?